Mobile Security Research Highlights @SNMS

Dr. Guan-Hua (Scott) Tu

Department of Computer Science and Engineering
Michigan State University
Email: ghtu@msu.edu
https://www.cse.msu.edu/~ghtu

The World Has Been Mobilized

- By the end of 2023,
  - Over 5.6 billion people globally subscribed to a mobile service, including 4.4 billion people who also used the mobile internet



Challenging to Secure Mobile Networks

- Is never an easy task to secure an operational mobile network
  - Is a complicated network
  - Simultaneously supporting multiple generations of mobile networks
    - E.g., a user can freely switch between 3G UMTS, 4G LTE, and 5G NR without terminating their ongoing services
  - However, security mechanisms and services vary with different generations of mobile networks
    - E.g., 3G UMTS supports circuit-switched voice/text services, whereas 4G/5G only supports packet-switched based ones

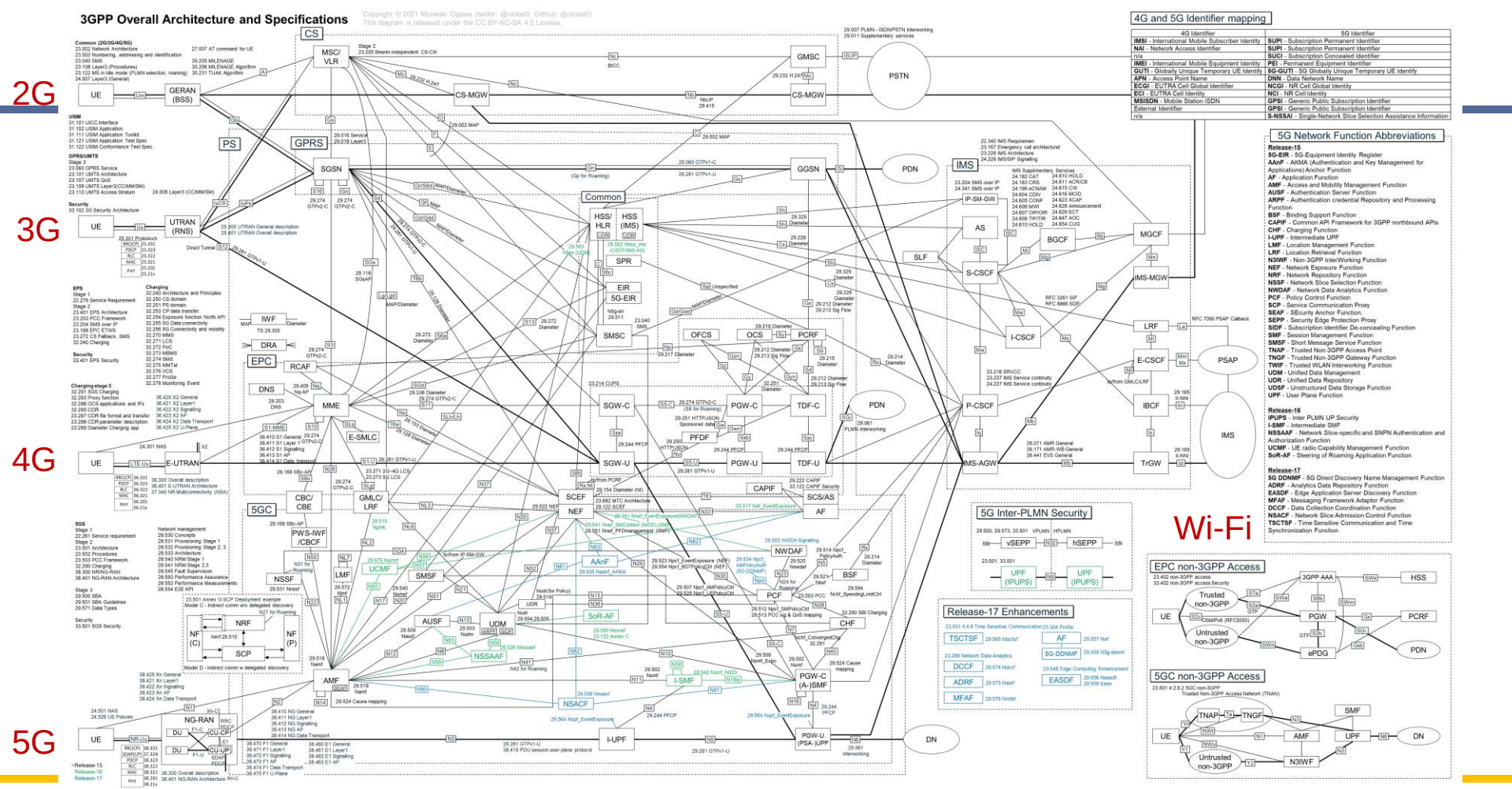


Image source: https://github.com/nickel0/3GPP-Overall-Architecture

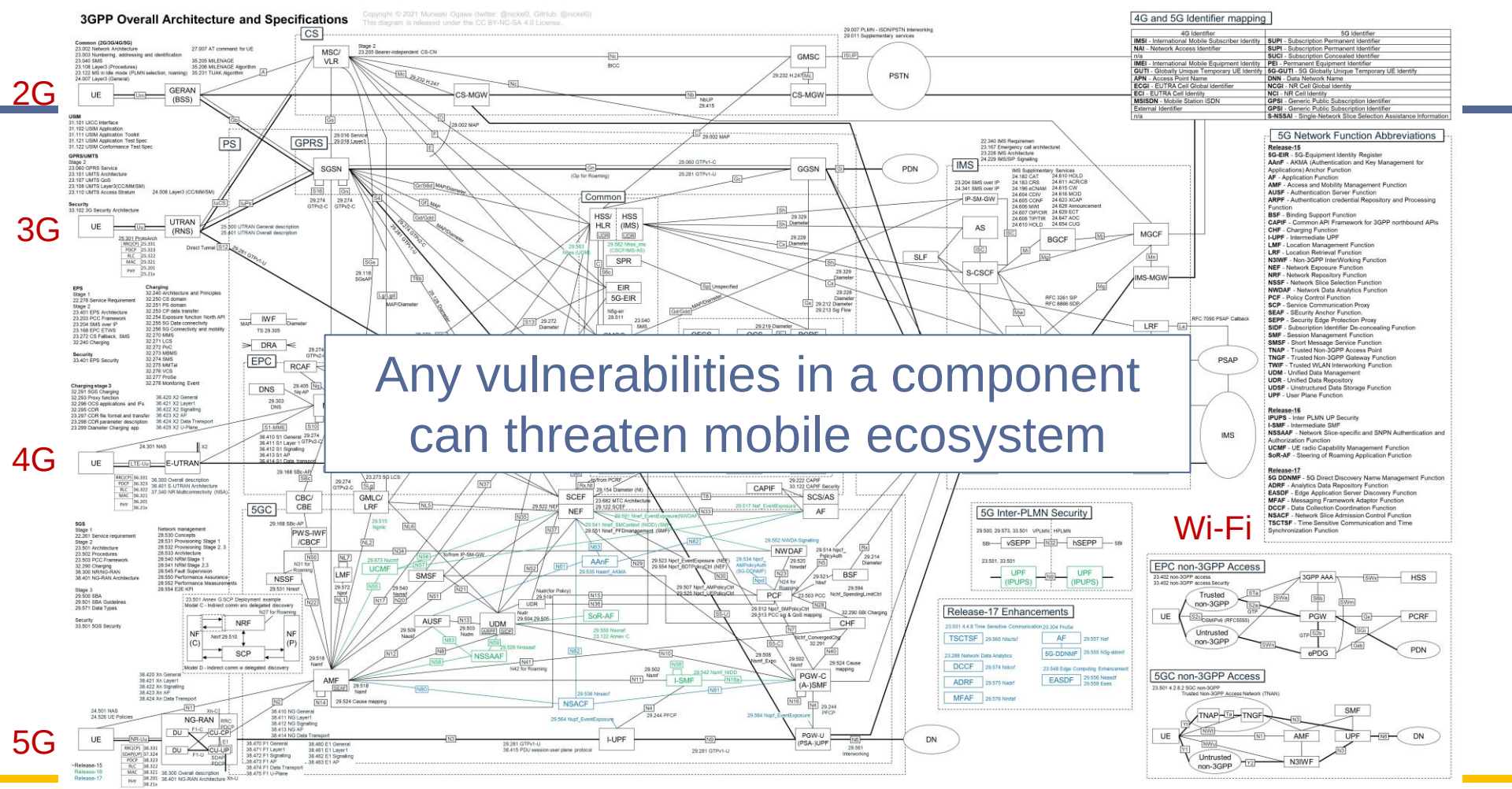


Image source: https://github.com/nickel0/3GPP-Overall-Architecture

Our Research Methodologies

- It is technically challenging to discover all possible security vulnerabilities in a hybrid mobile network

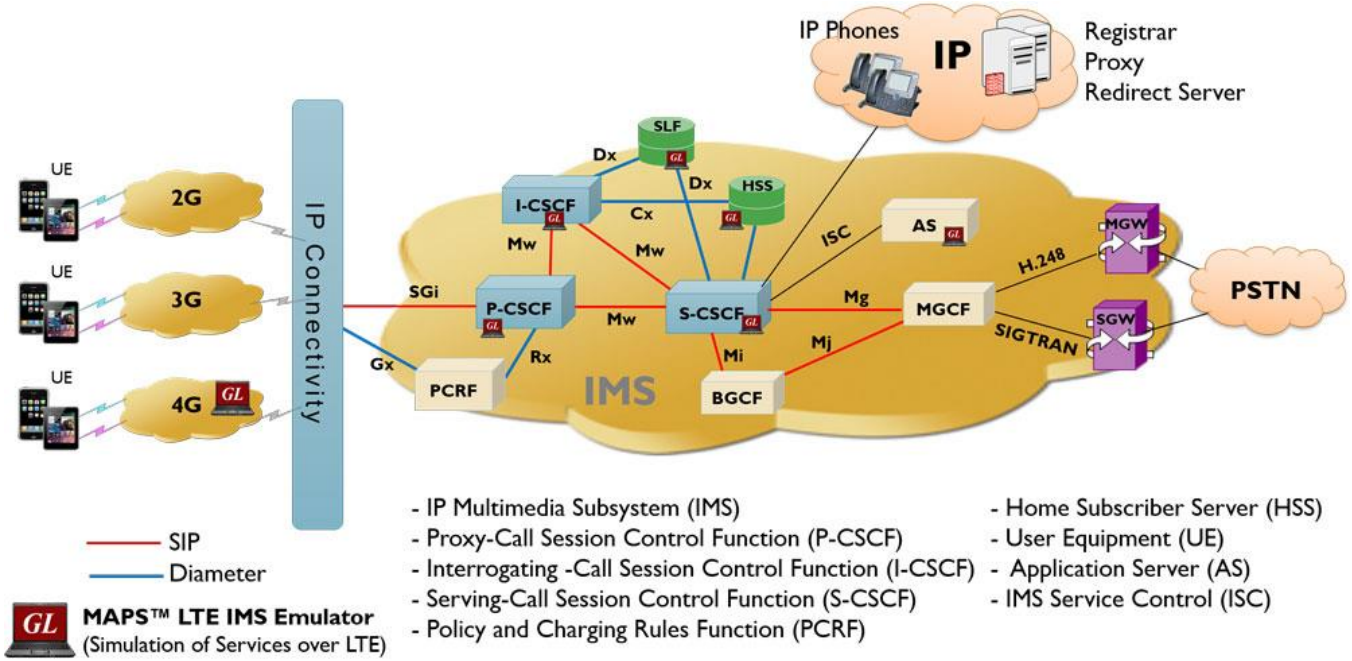
- We thus take a service-oriented approach
  - To explore the insecurity of essential mobile services (e.g., data, voice, text, IoT, and 911) including their design defects, implementation issues, and operational flaws
    - Using a variety of techniques, such as formal methods, wireless networking, artificial intelligence
  - Aim to identify practical security threats against mobile ecosystem

What is Service-oriented Approach?

- Study mobile ecosystem by using services
- For example, how is a voice call dialed from a 4G/5G phone?
  - Power on the phone, search for base stations, establish RRC connection, perform NAS attach/registration, establish bearers/PDN sessions, perform IMS registration, initiate IMS call using SIP
- How many network elements should be involved?
- How many protocols are involved?
- Are their designs or interactions problematic or insecure?
  - Identify problems based on your expertise

TS23.501: System architecture for the 5G System
TS23.502: Procedures for the 5G System (5GS)

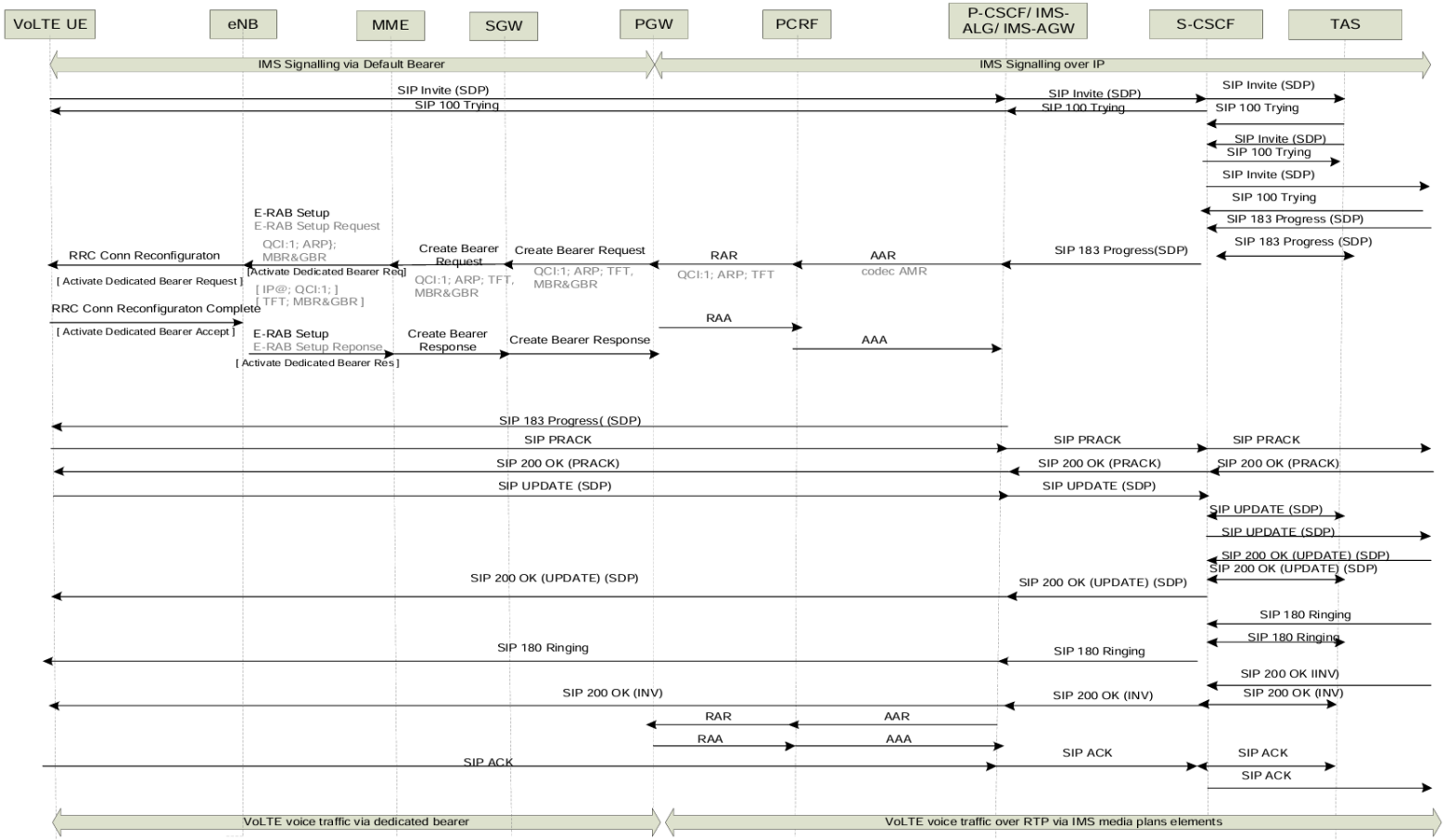
IMS (IP Multimedia Subsystem on top of IP)



BGCF: Breakout Gateway control function – selecting MGCF for S-CSCF
MGCF: Media Gateway control function
SLF: subscriber location function

Image source: https://www.gl.com/maps-ims-network-simulator.html
SGW: https://www.researchgate.net/figure/SS7-and-SIGTRAN-protocol-interconnection-structure_fig5_293158094

IMS Call Origination in 4G



Source: GSMA FCM.01-v1.1

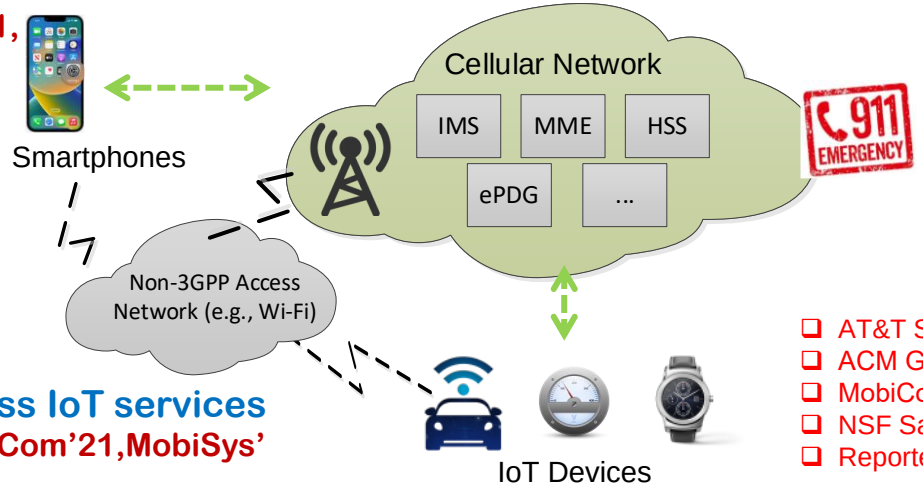
Our Current Contributions

(2) Taming cellular network IP Multimedia Subsystem (IMS) security (MobiCom'24,TON'22, TMC'21, MobiCom'20, CNS'18, CCS'16, CCS'15, MobiCom'13)

- Facebook Security Award
- Google Security Reward
- IEEE CNS'18 Best Paper Award
- NSF NeTS Award, 2023~26 ($600,000)
- NSF SaTC Award, 2018~23 ($500,000)

(4) Enhancing Mobile Service Charging Security (TMC'23, MobiCom'22, MobiCom'21, CCS'15, CCS'14, MobiCom'13, MobiSys'13 CCS'12,)

- Thank-you letters from Verizon security team
- Reported by MIT Review



(1) Safeguarding cellular emergency service security (9-1-1) (TON'24,GetMobile'23, MobiCom'22)

- AT&T Security Award
- ACM GetMobile'23 Research Highlights
- MobiCom'22 Best Community Paper Runner-up
- NSF SaTC Award ($1,200,000)
- Reported by Homeland Security News

(3) Securing wireless IoT services (TON'24,TMC'21,MobiCom'21,MobiSys'20,CNS'18, ICC'18)

- NSF NeTs Award, 2018~23 ($500,000)

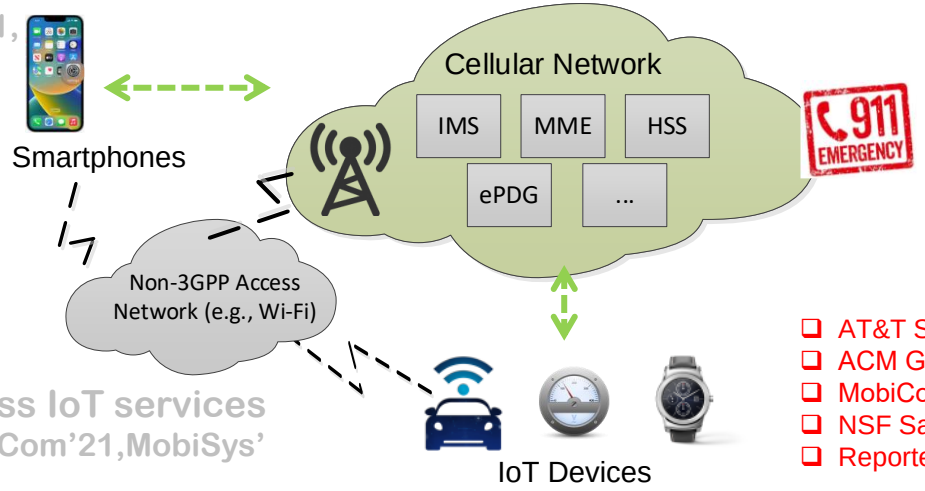
Our Current Contributions - 911

(2) Taming cellular network IP Multimedia Subsystem (IMS) security (MobiCom'24,TON'22, TMC'21, MobiCom'20, CNS'18, CCS'16, CCS'15, MobiCom'13)

- Facebook Security Award
- Google Security Reward
- IEEE CNS'18 Best Paper Award
- NSF NeTS Award, 2023~26 ($600,000)
- NSF SaTC Award, 2018~23 ($500,000)

(4) Enhancing Mobile Service Charging Security (TMC'23, MobiCom'22, MobiCom'21, CCS'15, CCS'14, MobiCom'13, MobiSys'13 CCS'12,)

- Thank-you letters from Verizon security team
- Reported by MIT Review



(1) Safeguarding cellular emergency service security (9-1-1) (TON'24,GetMobile'23, MobiCom'22)

- AT&T Security Award
- ACM GetMobile'23 Research Highlights
- MobiCom'22 Best Community Paper Runner-up
- NSF SaTC Award ($1,200,000)
- Reported by Homeland Security News

(3) Securing wireless IoT services (TON'24,TMC'21,MobiCom'21,MobiSys'20,CNS'18, ICC'18)

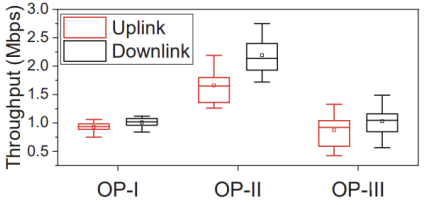
- NSF NeTs Award, 2018~23 ($500,000)

Cellular Emergency Service (9-1-1) Practice

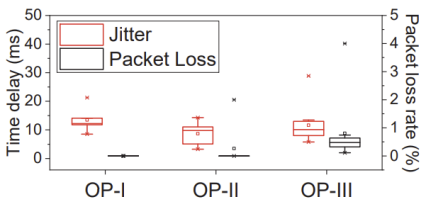
- To ensure the **availability** of cellular emergency services,
  - In the U.S., Federal Communications Commission (FCC) stipulates that cellular carriers must transmit all wireless 911 calls **without respect to their call validation** process to a Public Safety Answering Point (PSAP)
  - The GSM Association (GSMA) standard requires emergency services must be supported by all mobile phones even **without SIM cards** and be **free of charge** for mobile users
  - The 3GPP standard requires emergency services to be provided with **higher priority** than other cellular services

Free Services by Hijacking Emergency Services

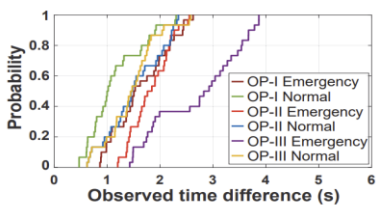
- **Hijacking Emergency IP-CAN Session**
  - **Two design defects are discovered from 3GPP standards**
    - V1: Non-atomic cellular emergency service initialization
    - V2: Improper access control on emergency IP-CAN sessions
  - **Adversaries thus gain free data/voice/text services**



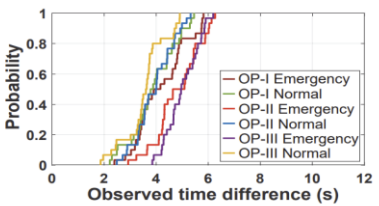
(a) Throughput.



(b) Packet loss rate and jitter.



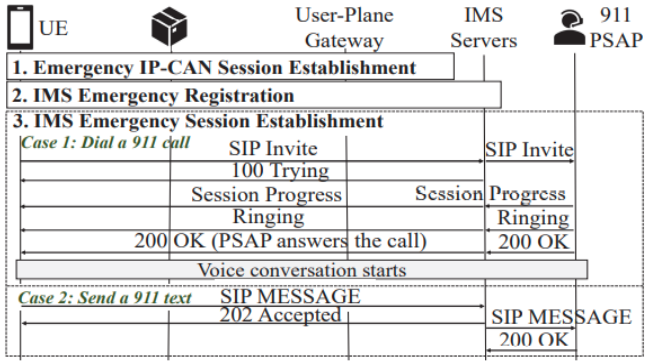
(a) Call setup time



(b) Text delivery time

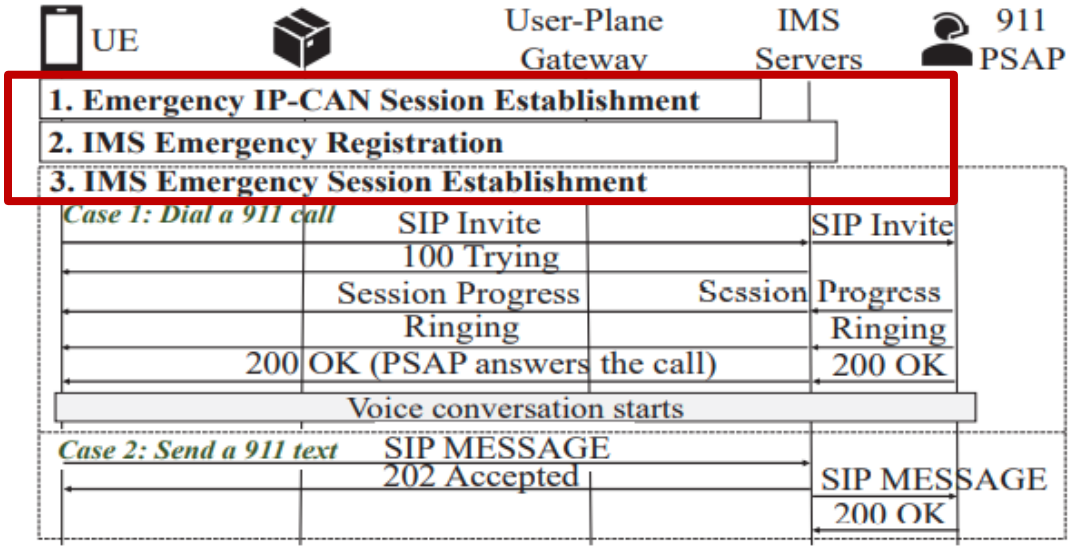
V1: Non-atomic Cellular Emergency Service Initialization

- Three actions are performed to initiate an emergency call
  - (1) Emergency IP-CAN Session Establishment
    - It allows the UE to obtain the emergency IP connectivity to communicate with the IMS server
  - (2) IMS Emergency Registration
    - It establishes a secure communication between the UE and the IMS server through IPSec
  - (3) IMS Emergency Session Establishment
    - It allows an emergency UE to establish an IMS emergency call/text session with the PSAP through the IMS server



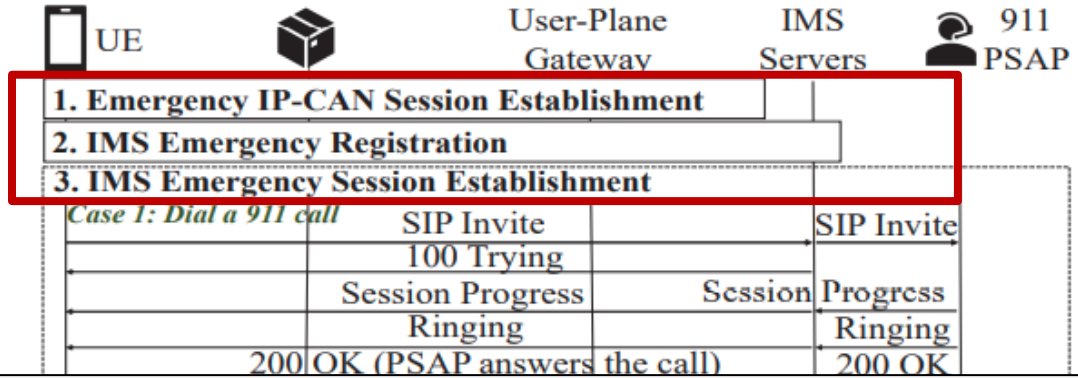
V1: Non-atomic Cellular Emergency Service Initialization

- Three emergency service initialization actions should be performed **without any interruption** - Atomicity
  - Otherwise, adversaries may abuse resources for non-emergency uses



V1: Non-atomic Cellular Emergency Service Initialization

- Three emergency service initialization actions should be performed **without any interruption** - Atomicity
  - Otherwise, adversaries may abuse resources for non-emergency uses



However, 3GPP standards do not stipulate mechanisms fulfilling this property !!

V2: Improper Access Control on Emergency IP-CAN Sessions

- The access of emergency IP-CAN session should **be restricted to IMS servers**; the access control should be done by **PCF** (Policy Control Function)

- **However,** the infrastructure (PCF) may not know which IMS servers will be assigned to users during emergency IP-CAN session establishment
  - According 3GPP, IMS server assignment can be done through DNS queries after IP address is assigned to the device
  - Then, after the assigned IMS server receives the UE's registration request, it needs to inform PCF so that the PCF can configure the access control correctly (TS23.380)

V2: Improper Access Control on Emergency IP-CAN Sessions

- According 3GPP, IMS server assignment can be done through DNS queries after IP address is assigned to the device
  - Therefore, after the assigned IMS server receives the UE's registration request, it needs to inform PCF

What if the UE does not perform IMS emergency registration towards the assigned IMS server?

  - PCF will NOT receive notifications from IMS servers, and the access control of emergency IP-CAN session may NOT be configured properly
    - None of the top three U.S. carriers set up the access control without any errors

Carriers	Mobile-to-Internet	Mobile-to-Mobile		
		E2E	E2IMS	E2D
OP-I	X	O	X	X
OP-II	X	O	X	O
OP-III	X	O	O	O

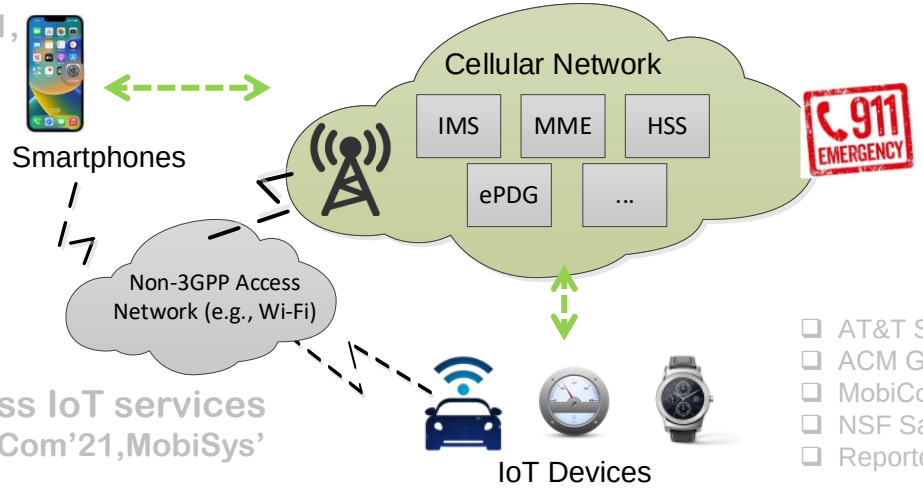
Our Current Contributions - IMS

(2) Taming cellular network IP Multimedia Subsystem (IMS) security (MobiCom'24,TON'22, TMC'21, **MobiCom'20, CNS'18**, CCS'16, CCS'15, MobiCom'13)

- Facebook Security Award
- Google Security Reward
- IEEE CNS'18 Best Paper Award
- NSF NeTS Award, 2023~26 ($600,000)
- NSF SaTC Award, 2018~23 ($500,000)

(4) Enhancing Mobile Service Charging Security (TMC'23, MobiCom'22, MobiCom'21, CCS'15, CCS'14, MobiCom'13, MobiSys'13 CCS'12,)

- Thank-you letters from Verizon security team
- Reported by MIT Review



(1) Safeguarding cellular emergency service security (9-1-1) (TON'24,GetMobile'23, MobiCom'22)

- AT&T Security Award
- ACM GetMobile'23 Research Highlights
- MobiCom'22 Best Community Paper Runner-up
- NSF SaTC Award ($1,200,000)
- Reported by Homeland Security News

(3) Securing wireless IoT services (TON'24,TMC'21,MobiCom'21,MobiSys'20,CNS'18, ICC'18)

- NSF NeTs Award, 2018~23 ($500,000)

5G/4G VoWiFi: Get Stuck in Dialing

- VoWi-Fi allows users to access IMS services via Wi-Fi rather than cellular radio access networks
  - It adopts all IMS security mechanisms, including IMS AKA
  - All VoWi-Fi signaling, and traffic are transmitted using IPSEc
  - Additionally, a system-switch (Wi-Fi-to-Cellular) mechanism is deployed to defend against DoS attacks
    - However, it only protects the transmission of SIP INVITE

The Dark Side of Operational Wi-Fi Calling Services,, IEEE Communications and Network Security (CNS)'18 (Best Paper Award, Google Security Reward)

5G/4G VoWiFi: Get Stuck in Dialing

- **Call Stuck Attack**
  - Adversaries can get caller stuck in their dialing screen while suppressing the system-switch (Wi-Fi to Cellular) security mechanism
  - By discarding callee's 200 OK (answering the call), caller cannot hear callee's voice even phone already receives their voice packets

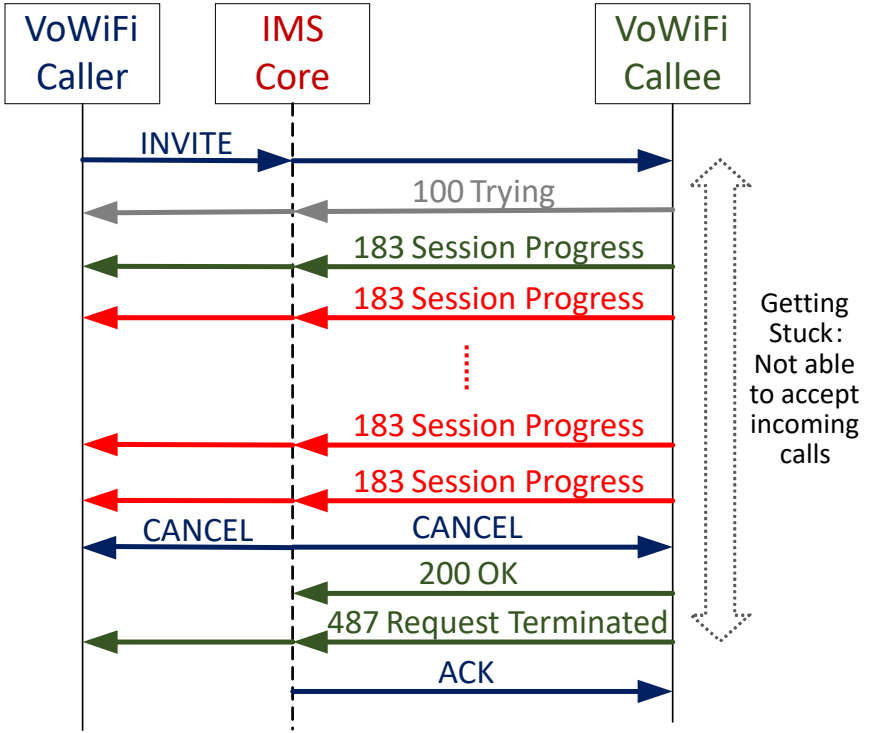
No.	Dropped Packets	Sender	Results
1	INVITE	Caller	Caller initiates a cellular-based call.
2	100 Trying	Server	No effect.
3	183 Session	Callee	Two outgoing calls arrive at callee.
6	180 Ringing	Callee	Caller will not enter conservation state. His/her phone gets stuck in the dialing screen.
7	PRACK	Caller	No effect.
8	200 OK	Callee	Caller keeps hearing the alerting tone.
9	200 OK	Callee	Caller keeps hearing the alerting tone.
10	ACK	Caller	No effect.
11	Voice Packets	Caller /Callee	Call drops or voice quality downgrades.
12	BYE	Caller	Callee gets stuck in the conversation state for 20s. Afterwards, the call is terminated.

Phones (call applications) do not help users prevent/escape from this attack

The Dark Side of Operational Wi-Fi Calling Services,, IEEE Communications and Network Security (CNS)'18 (Best Paper Award, Google Security Reward)

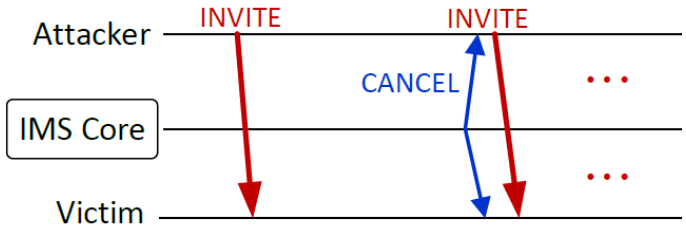
VoLTE/VoNR/VoWiFi: Silent Call DoS Attack

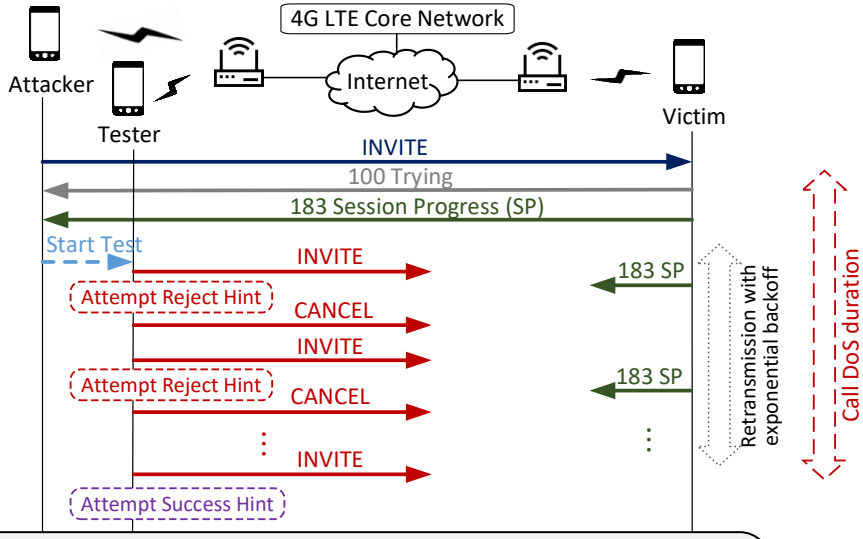
- Abusing the reliability of provisional responses
  - Retransmission with an exponential backoff timer
  - On receipt of 183 Session Progress, caller needs to reply PRACK to callee
- However, it can get the callee stuck in the "proceeding" state
  - Prevent the callee from accepting other incoming calls



VoLTE/VoNR/VoWiFi: Silent Call DoS Attack

- On receipt of CANCEL from IMS server, adversaries send another INVITE to the victim



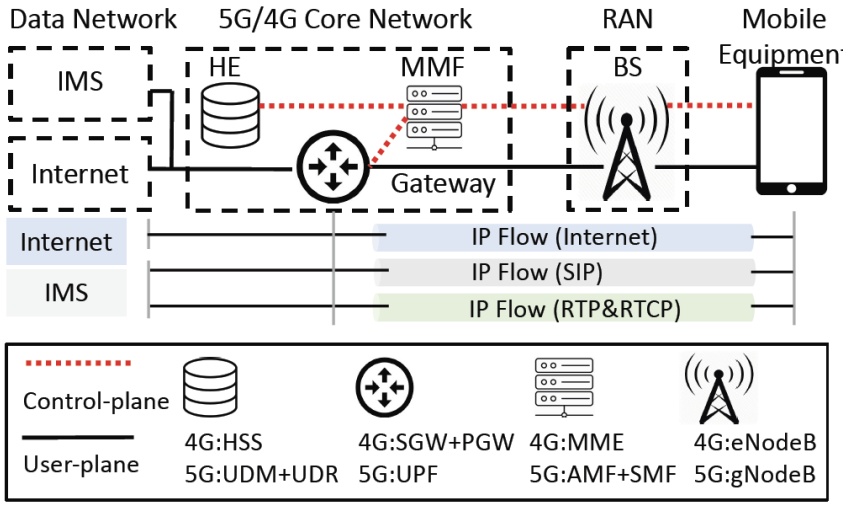


- Experimental results

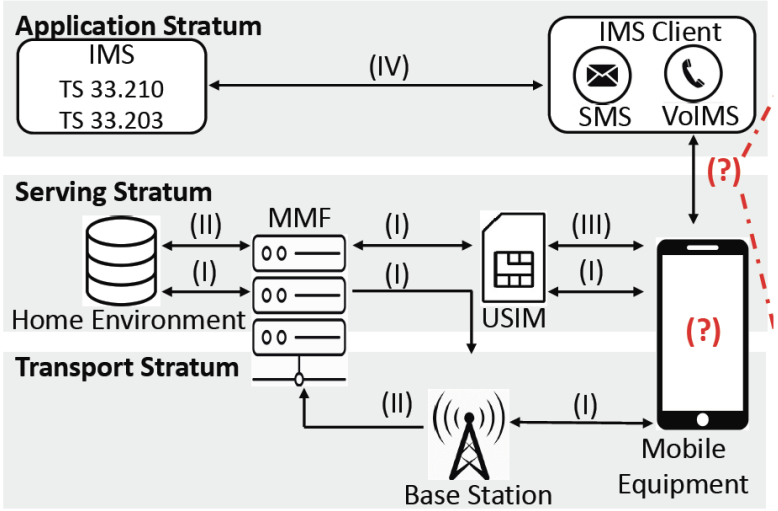
Phones don't provide users with any notifications regarding unestablished call attempts

to 97% of time without user awareness

Future Research Direction: ME Security



(a) 5G/4G network service architecture



(b) 5G/4G network security architecture

Questions & Answers



Thanks!